

CWE AI Working Group: Modification Subgroup

August 1, 2025

Attendance

Steve Christey Coley

Lee Szilagyi

Monika Akbar

Caroline Rocha

Ray Pompon

Tonisha Pinckney

Michael Simon

Farah Rahman

Agenda

- Status Updates
- Identifying Observed/Demonstrative Examples for “General” CWEs
- Identifying AI/ML “Classes”

Meeting Notes:

Status Updates: Steve provided an update on the next CWE release (4.18), which is scheduled for the end of the month, possibly around the 27th or 24th. He mentioned that they will be tagging some CWEs with AI/ML as an affected technology and introducing a new entry related to insecure model hyperparameters.

- A final check-in meeting with the new entry subgroup for the insecure model hyperparameters entry is planned in a couple of weeks, and the new entry information will be shared with everyone next week.

Identifying Observed/Demonstrative Examples for “General” CWEs: Steve discussed the importance of identifying observed examples of weaknesses that affect AI and machine learning products. He emphasized the need to find and label additional weaknesses beyond the five already identified, and to modify Affected_Platforms elements in the CWE to indicate their impact on AI and machine learning.

- **Modifying CWE:** The Affected_Platforms elements in the CWE will be modified to indicate their impact on AI and machine learning. This involves updating CWEs to reflect their relevance to AI and machine learning products.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- **Demonstrative Examples:** Steve mentioned that creating demonstrative examples for AI-specific weaknesses takes a lot of time and effort. He suggested that they might not be able to define these examples cleanly enough for the next CWE release, but they can still review and discuss some of the best observed examples. This involves looking at potential examples that can be used to illustrate AI-specific weaknesses.
- **CVE Keyword Searches:** Steve shared that he had conducted keyword searches on CVE for various product labels and found hundreds of possibilities. He proposed that the group could look through these to identify which ones affect the most relevant weaknesses.
 - **Task Division:** The group discussed dividing the work of searching through CVEs. This could involve looking at specific weaknesses or product names to identify relevant CVEs.
 - **Automation:** There was a suggestion to automate some of the search processes using a list of product names as keywords. This approach could help in retrieving relevant CVEs more efficiently.
- **AI / ML Products:** Steve and the group discussed various AI machine learning products, including machine learning platforms, model providers, libraries, SDKs, and frameworks. They aimed to create a list of products to use as keywords for CVE searches.
 - **Product Categories:** The group discussed various categories of AI machine learning products, including machine learning platforms, model providers, libraries, SDKs, and frameworks. They aimed to create a comprehensive list of products for CVE searches.
 - **Supply Chain Security:** Lee highlighted the importance of supply chain security in relation to model serving platforms like Hugging Face. The potential risks of using vulnerable plugins were discussed.
 - **Content Generators:** The group discussed AI content writers and content generators, suggesting products like Adobe Firefly, Canva, Copilot, Perplexity, ChatGPT, and Gemini. They aimed to identify vulnerabilities in these products for their CVE searches.
 - **Chatbots:** The group briefly discussed chatbots and their integration into major LLM models. They mentioned specific products like Chatterbot and Botpress as examples to consider for their CVE searches.

- **Next Steps:** Steve concluded the meeting by thanking everyone for their suggestions and outlining the next steps. He plans to conduct CVE searches based on the product list and present a candidate set of CVEs for review in the next meeting.

Action Items:

- **Update CVE Searches:** Include model providers (Hugging Face, Nemo), libraries and SDKs (Hugging Face Transformers, Keras, Scikit-learn, Numpy, Matplotlib), frameworks (Rasa, DialogueFlow CX, Deep Pavlov) models (DeepSeek, Claude, GPT family, Yolo), content generators (Adobe Firefly, Canva Magic Studio, Copilot, Perplexity, ChatGPT, Gemini). Other updates may be included in the presentation slides, which were updated during the meeting, (Steve)